

Política de Gestão de Vulnerabilidades

Identificação, classificação, tratamento, validação e registro de vulnerabilidades em código, dependências, banco e infraestrutura.

Código	NRX-SEC-VUL-001	Versão	1.0
Responsável	Jhonatan Gasperi de Oliveira	Vigência	01 de julho de 2026
Classificação	Uso controlado	Próxima revisão	01 de julho de 2027

VIGENTE

Documento aprovado para uso interno e apresentação como evidência institucional, sujeito às revisões e controles descritos.

1. Objetivo

Estabelecer uma rotina proporcional ao risco para localizar e corrigir vulnerabilidades antes que resultem em acesso indevido, exposição de dados, fraude financeira, indisponibilidade ou descumprimento contratual.

2. Fontes de identificação

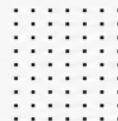
- GitHub Actions, Dependabot, Snyk, npm audit e demais analisadores de dependência.
- Gitleaks e varreduras de secrets em Pull Requests e commits.
- Revisão de código, testes automatizados e análise de Pull Requests.
- Supabase Security Advisor, revisão de RLS, grants, funções privilegiadas e Edge Functions.
- Alertas e comunicados de Asaas, Supabase, Vercel, Cloudflare, GitHub e outros fornecedores.
- Relatos de usuários, pesquisadores, suporte e incidentes anteriores.

3. Classificação e prazos-alvo

Nível	Critério	Prazo-alvo
Crítico	Bypass de autenticação/RLS, credencial exposta, fraude financeira direta ou exposição ampla de dados sensíveis.	Contenção imediata; plano em até 24h; correção antes de release.
Alto	Exploração provável com impacto relevante em produção, finanças ou dados pessoais.	Plano em até 7 dias; correção priorizada.
Médio	Exploração limitada, dependente de condições específicas ou mitigada por controles compensatórios.	Prazo definido no backlog, normalmente até 30 dias.
Baixo	Impacto reduzido, melhoria preventiva ou dependência sem exposição material.	Tratamento programado e acompanhado.

4. Processo de tratamento

- Registrar a vulnerabilidade com ID, fonte, data, componente e evidência sanitizada.
- Classificar severidade, probabilidade, impacto e exposição do componente.
- Definir responsável, prazo, controle compensatório e decisão de release.
- Corrigir em branch separada, executar revisão, testes, build e secret scan.
- Validar a correção e confirmar ausência de regressão funcional ou de autorização.
- Registrar risco residual, evidência de fechamento e data da próxima revisão.



5. Regras de release

- Vulnerabilidade crítica aberta impede release em produção, salvo decisão emergencial documentada e controle compensatório aprovado.
- Vulnerabilidades altas devem ser corrigidas antes do release quando afetarem o caminho executável de produção.
- Achados de ferramentas de desenvolvimento podem ser tratados por plano de atualização quando não integrarem o runtime produtivo, desde que o risco seja documentado.
- Checks obrigatórios de Pull Request não devem ser desativados para contornar falhas; falsos positivos exigem exceção mínima, específica e revisável.

6. Banco de dados e autorização

Revisões devem considerar RLS, grants de anon/authenticated, funções SECURITY DEFINER, search_path, storage, URLs assinadas, segregação profissional/paciente e acesso financeiro. Mudanças estruturais devem ser testadas primeiro em ambiente não produtivo ou por estratégia de baixo risco devidamente aprovada.

7. Secrets e credenciais

Qualquer secret confirmado em repositório, log ou captura é tratado como incidente. O valor deve ser revogado ou rotacionado, removido da origem, investigado no histórico e substituído por armazenamento server-side.

8. Registros e métricas

- Quantidade de vulnerabilidades por severidade e status.
- Tempo médio para contenção e correção.
- Achados reabertos ou recorrentes.
- Exceções e controles compensatórios vigentes.
- Evidências de CI, scans, Advisors e testes de autorização.

9. Revisão

O registro de vulnerabilidades deve ser revisado mensalmente. Esta política deve ser revisada anualmente ou após incidente crítico, alteração relevante da arquitetura ou mudança de fornecedor crítico.

Aprovação

Aprovo este documento e determino sua aplicação a partir da data de vigência indicada.

Jhonatan Gasperi de Oliveira

Responsável e aprovador institucional

Assinatura digital: _____ Data: 01/07/2026